

- The types of customers using the products and services.
- The geographic service footprint (e.g., international usage)
- Check processing, particularly check imaging, remotely created checks (RCCs), and remote deposit capture
- ACH, including third-party originations, TEL, WEB, ARC, POP, and BOC
- Card issuance
- Card processing
- Merchant acquisition and processing

2. Determine whether new retail payment products and emerging technologies pose increased risk due to the lack of maturity of the respective control environments. Consider:

- New retail payment products and services that have been introduced within the past year.
- Whether the institution introduced any existing products into new markets within the past year.

3. Determine if the quality of management and staff, and the staffing levels are adequate for the specific retail payment products and processes the institution provides.

- Obtain and review the following:
 - Reports showing staffing levels, turnovers, and trends.
 - Biographies of managers and key staff
- Consider:
 - The levels of skill and experience of key managers and staff, particularly in terms of the sophistication and complexity of the products, processes, and systems.
 - Whether the institution has appropriate depth of management and staff.
 - The adequacy of staffing levels for peak operating periods.

Management and staff turnover.

4. Determine if the quality of process design and control points are adequate for existing retail products, and if these factors are considered for new products. Consider whether:

- There is adequate capacity for current and planned transaction volumes.
- Processes are clearly designed.
- Processes are automated.
- There is a reasonable degree of manual intervention.
- Any processes have been re-engineered during the past year.
- Processes are outsourced or performed at the customer location.

5. Evaluate the use of in-house and outsourced data processing systems to support retail payment products and processes. Consider:

- How stable are existing systems.
- How current are existing systems.
- Whether there is adequate capacity for current and planned transaction volumes.
- Whether the institution uses leading edge technologies or only mature technologies.
- To what extent are systems outsourced.
- Whether outsourcing arrangements are governed by contracts and service level agreements.
- Whether vendors are considered to be industry-recognized leaders.

Objective 2: Establish the scope and objectives of the examination of the retail payment systems function.

1. Review previous reports of examination for comments relating to retail payment systems. Review:

- Regulatory reports of examination, including consumer and compliance information.
- Prior examination work papers, including any documentation obtained through on-going supervision.
- Internal control self-assessments completed by business lines.
- Internal and external audit reports, including annual attestation letters.
- Regulatory, audit, and information security reports from service providers.

- Trade group, bankcard company, interchange, and clearing house documentation relating to services provided by the financial institution, particularly the NACHA required annual security audit and bankcard company self assessments.
- Supervisory strategy documents, including risk assessments.

2. Review past examination reports for comments relating to the institution's internal control environment and technical infrastructure. Review:

- The institution's processing architecture, including processing outsourcing arrangements.
- Internal controls, including physical and logical access controls in the data entry area, data center, and item processing operations.
- Electronic Funds Transfer (EFT)/Point of Sale (POS) network controls.
- Comments related to controls over Remote Deposit Capture (RDC).
- Inventory of computer hardware, software, and telecommunications protocols used to support check item processing, EFT/POS transaction processing, ACH, and bankcard issuance and acquiring transaction services.

3. Review the financial institution's risk and control assessments for comments relating to retail payment systems. Review the following risk assessments:

- External and internal audit;
- Management controls;
- Information security;
- Business continuity;
- Regulatory compliance; and
- BSA/AML.

4. Identify and obtain during discussions with management of financial institution or service provider:

- A description of the retail payment system activities performed and scope of operations, including check item processing, RDC, lock-box services that provide ACH check conversion or check truncation, ACH, bankcard issuing and acquiring,

clearance, settlement, and EFT/POS network activity.

- Operational reports for retail payment system activities, including transaction volumes, dollar amounts, and trends. Where possible, compare levels and trends with peer financial institutions. Significant increases may indicate a change in risk to the financial institution and management awareness should be evaluated.
- Organization charts of retail lines of business to determine reporting relationships and how the collective retail lines of business are structured and managed.
- The retail payment system functions performed through outsourcing relationships and the financial institution's level of reliance on those services.
- Any significant changes in retail payment system policies, personnel, products, strategy and services since the last examination, particularly the introduction of new and emerging electronic retail payment systems incorporating RDC, wireless, telephone, web-based purchasing and bill payment, prepaid cards, or P2P and A2A payment systems.
- A listing of all payment processing and clearing house settlement arrangements in which the financial institution participates. Include any bilateral retail payment clearing arrangements the institution may have with other institutions that are outside traditional clearing houses such as FedACH and EPN. Evaluate the methodology used by the financial institution in assessing its operational and settlement risk from these arrangements.
- Documentation of any related operational or credit losses incurred, reasons for the losses, and actions taken by management to prevent future losses for each retail payment system.
- A network diagram of the transaction flow from the merchant end of the network, through any intermediary processors, to the financial institution, for all types of payment channels.

5. Review the financial institution's response to any retail payment systems issues raised at the last examination and any internal audits conducted since last review. Determine:

- Adequacy and timing of corrective action.
- Resolution of root causes rather than specific issues.
- Existence of outstanding issues.

Objective 3: Assess the quality of oversight and support provided by the board of directors and management.

1. Determine the quality and effectiveness of the financial institution's retail payment systems management function. Consider:

- The alignment of the institution's business plans with its technology and operational plans for retail payment systems.
- Data center and network management and the quality of internal controls over internal ATM networks and gateway connectivity to regional, national, and international EFT/POS and bankcard networks.
- Departmental management and the quality of internal controls, including separation of duties and dual control procedures, for bankcard, ATM and debit card, ACH, check items, and electronic banking payment transaction processing, clearance, and settlement activity.
- Departmental management and the quality of information security and GLBA 501(b) compliance policies relating to retail payment system-generated customer data.

2. Assess management's ability to manage outsourced relationships with technology service providers. Consider:

- Process utilized to encrypt transactions while in route between technology service providers and the institution.
- Adequacy of contract provisions including service level, performance agreements, responsibilities, liabilities, and management monitoring.
- Management's determination of the service provider's compliance with applicable financial institution and consumer regulations and with third-party requirements (e.g., NACHA, GLBA, bankcard company, and interchange).
- Adequacy of contract provisions for personnel, equipment, and related services.
- Quality of management information systems (MIS) and reports needed to monitor the technology service provider's performance appropriately.

3. Evaluate the adequacy and effectiveness of financial institution and service provider contingency and business continuity planning. Consider:

- Ability to recover transaction data and supporting books and records based on retail payment system business line requirements and time lines.
- Level of testing conducted to ensure adequate preparation.
- Stand-in arrangements established with other financial institutions in the event of an ATM and/or POS system outage. preventing card fraud and abuse.
- Alternative access mechanisms in the event of an outage to primary access to bankcard, ACH, and other retail payment networks.

4. Evaluate retail payment system business line staff. Consider:

- Adequacy and quality of staff resources, including certifications such as an Accredited ACH Professional (AAP).
- Effectiveness of policies and procedures outlining department duties, including job descriptions.

Objective 4: Assess the quality of policies, procedures, and limits supporting retail payment services.

1. Review policies, procedures, and limits for supporting all retail payment services.

- Determine if there are written policies.
- Determine if the policies reflect the current business and processes.
- Determine if the policies establish reasonable limits.

2. Review staff training programs and determine if they are appropriate for supporting policies.

3. Determine whether the institution monitors compliance with policies, procedures, and limits.

- Determine if exception monitoring reports are elevated to appropriate levels of management.

Objective 5: Assess the quality of management information systems and reports used to manage retail payment services.

1. Review management reports for all retail payment services including reports from service providers.

- Determine if the reports are appropriate to the businesses and processes in terms of scope and frequency.
- Determine if the reports are reviewed at the appropriate levels of management.

Objective 6: Assess the quality of risk management and support for bankcard issuance and acquiring (merchant processing) activity.

1. Evaluate financial institution adherence to bankcard company rules and bylaws and regulatory requirements.
2. Evaluate whether card issuance processing is outsourced to a third party. If yes, evaluate the vendor management controls in place to govern the activities listed in steps 3 and 4.
3. Review internal procedures employed for each bankcard product and assess:
 - The integrity of plastic card and PIN issuance processing.
 - Whether processing includes appropriate separation of functions in card issuance, PIN issuance, control and storage of card stock, and the maintenance of software controlling PIN generation.
 - Whether the institution has established procedures focusing on controls preventing card fraud and abuse.
4. Determine whether the audit function periodically performs an inventory of all bankcards at each location owned or operated by the institution and that each location is included in the audit program, either directly or indirectly (e.g., as part of a branch audit).
5. Determine whether management has established inventory systems that include quality control activities such as self-monitoring for data accuracy.
6. Review a sample of consumer contracts for each bankcard service to ensure they describe adequately the responsibilities and liabilities of the institution and its customers (compliance with Regulation Z).
7. Evaluate the effectiveness of internal clearance and settlement activity as it relates to customer bankcard transactions. Consider the adequacy of:
 - Financial and accounting controls in place to clear and settle transactions.
 - Periodic reconciliation of all account postings.
 - Timely clearance or charge-off of missing items or out-of-balance situations.
8. Evaluate the effectiveness of internal credit monitoring and card authorization performed by the financial institution. Consider the adequacy of:
 - Policies and procedures for underwriting, account management, and collection activities.
 - Card authorization procedures to mitigate fraudulent use.

- MIS reports and behavioral fraud analysis.

9. For financial institutions directly involved in, or outsource, bankcard acquiring (merchant processing) services, determine the appropriateness of controls over merchant services and ISO/MSP relationships. Consider the adequacy of:

- New merchant approval and acceptance process, termination procedures, and underwriting guidelines for merchant accounts with particular attention to Web and telephone-based businesses.
- Testing of web-based business to validate site's content.
- Industry-standard MIS reports to identify negative trends and potential fraudulent activity. Potential indicators of fraud or money laundering include: a large number of manually keyed transactions, even dollar amount transactions, average sale ticket size as compared to history, same dollar amount repeated frequently in a single batch, or continuous or frequent zero balances in DDA account.
- The financial institution's use of a front-end fraud detection application either in-house design or purchased.
- Credit approval and monitoring procedures for all new and established merchant accounts. Consider use of Dun & Bradstreet reports, bank statements and credit reports.
- Chargeback processing procedures and controls, including trend, volume, age, and losses associated with merchant chargebacks.
- Agent bank programs (where the financial institution performs merchant processing for other institutions), and the level of liability assumed by the acquiring financial institution.
- Protection and storage of cardholder data and compliance with card company rules and guidelines on what data can and cannot be stored.
- Programs for requiring and monitoring merchant's and processor's compliance with card company and association standards such as PCI Data Security Standards. Review assessment document and process for completion.
- Policies and procedures relating to customer accounts that may have been the subject of security breach at the merchant/ISO location (i.e., reissue cards, monitoring and customer notification).

Objective 7: Assess the quality of risk management and support for EFT/POS processing activity.

1. Evaluate the financial institution's compliance with interchange rules and bylaws.
2. Review internal procedures employed for generating active ATM cards. Consider:

- The integrity of PIN issuance and processing, including appropriate separation of functions between card issuance, PIN issuance, and card stock control and storage.
- The maintenance of software controlling PIN generation. The review should focus on controls preventing card fraud and abuse resulting in financial loss to the institution.

3. Determine whether the audit function periodically performs an inventory of unused ATM card stock at each location owned or operated by the institution and that each location is included in the audit program, either directly or indirectly (e.g., as part of a branch audit).

4. Review a sample of consumer contracts for ATM services to ensure they adequately set forth responsibilities and liabilities of the institution and the customer. Evaluate compliance with applicable regulations.

5. Evaluate the effectiveness of internal clearance and settlement activities as it relates to customer ATM transactions. Consider whether:

- Appropriate financial and accounting controls are in place to clear and settle ATM transactions.
- Reconciliation is performed periodically for all account postings.
- Processes have been established for handling disputed items.

Objective 8: Assess the quality of risk management and support for ACH processing activity.

1. Evaluate the financial institution's adherence to NACHA and clearing house operating rules and regulations.

2. Review operational reports showing monthly or quarterly ACH debit and credit activity and, if possible, compare levels with peer financial institutions. If ACH activity is greater than peer, determine whether institution is an originating institution (ODFI). Obtain reports listing those customers for which they originate and the volumes (number of items and dollars) originated. Be sure to ask for all customers that use the ODFI's originating account number with the Federal Reserve or EPN.

3. If the institution has bilateral clearing arrangements with other institutions, review the underlying contracts and determine how the institution monitors compliance with the contracts.

4. If the institution uses a technology service provider, determine whether it performed appropriate due diligence prior to engagement and has appropriate contractual agreements governing the relationship. Determine whether the institution monitors compliance with the governing contract. Determine if the institution has an adequate business continuity plan in the event the technology service provider experiences a service disruption.

5. If the institution is an ODFI and permits third-party sender payments, determine whether it requires the third-party sender to establish the identity of each originator using commercially reasonable methods to warrant that the originators will assume their responsibilities under NACHA rules and to warrant that it will assume the liabilities of the ODFI. Determine whether the ODFI has established limits and monitoring of the third-party sender's creditworthiness relative to its underlying originators and the nature and type of ACH activity that it warrants.
6. Determine whether the ODFI's contractual agreements with each originator clearly define the specific terms for funds availability.
7. Determine whether the institution has taken steps to ensure that originators are properly educated about their obligations for handling ARC and POP source documentation and all other NACHA rules.
8. Review policies and procedures for acquisition of originating customers and determine the appropriateness of these policies for the risk profile and risk management capabilities of the financial institution. Determine whether the policies identify and seek to limit exposure to higher risk customers; such as, adult entertainment and online gambling firms, adult bookstores, escort services, and massage parlors.
9. Review policies and procedures in place to monitor originating customer balances for credit payments (e.g., payroll) to ensure payments are made against collected funds or established credit limits and daily caps. Also determine whether payments in excess of established credit limits and daily caps are properly authorized.
10. Determine whether the institution treats deposits resulting from ACH transmitted debits on other accounts as uncollected funds until there is reasonable assurance the debits have been paid by the institution on which they were drawn. Also, determine whether management monitors drawings against uncollected funds to ensure they are within established guidelines.
11. Review a sample of contracts authorizing the institution to originate ACH items for customers and determine whether they adequately set forth the responsibilities of the institution and customer. Determine:
 - Whether contracted technology service providers originating customer entries are also customers of the financial institution.
 - Whether the agreements include recognition of all relevant NACHA requirements.
 - Whether ACH clearing houses, of which the financial institution is a member, stipulate the funding arrangements (outgoing), Expedited Funds Availability Act (Regulation CC), UCC Article 4A (credit transfer only), and Electronic Funds Transfers (Regulation E).
12. Determine whether the institution has a process in place for monitoring and acting on returned items, that includes third-party vendors, where applicable..
13. Determine whether the institution uses risk management reports that are appropriate to the ACH activities and level of risk.